

Informe LINDDUN 2025–2026: Indicadores, Métricas Cuantitativas y Aplicación Territorial en España

"La privacidad no es un privilegio técnico, sino una condición civilizatoria: medirla con rigor es el primer acto de respeto hacia quienes la necesitan."

Resumen Ejecutivo

El marco LINDDUN (Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness, Non-compliance) representa el estado del arte en modelado de amenazas para la privacidad. Desarrollado por el grupo DistriNet de KU Leuven desde 2010, ha evolucionado hasta convertirse en el único marco de modelado de amenazas de privacidad reconocido por el NIST, incorporado en la norma ISO 27550 sobre ingeniería de privacidad y activamente citado en la literatura académica como método primario para operacionalizar el Artículo 25 del RGPD.^{[1][2][3]}

En el período 2025–2026, LINDDUN ha experimentado su fase de maduración más significativa: la publicación de LINDDUN Maestro como marco de arquitectura avanzada; la extensión formal del marco hacia sistemas de Inteligencia Artificial Generativa mediante 100 nuevos ejemplos de amenazas; la formalización de su base de conocimiento mediante un metamodelo ontológico; y la adopción institucional en España por la Agencia Española de Protección de Datos (AEPD), que ha derivado de él el propio marco LIINE4DU 1.0. Todo ello en un contexto en el que España registró en 2025 un máximo histórico de 2.765 notificaciones de brechas de datos personales y 122.223 incidentes de ciberseguridad, un 26% más que el año anterior.^{[4][5][6][7][8][9][10][11]}

Este informe sistematiza, con rigor académico y vocación aplicada, los siete indicadores del marco, sus métricas cuantitativas propuestas por la literatura más reciente, y su proyección sobre el territorio español con perspectiva comparada mundial.

I. El Marco LINDDUN: Fundamentos y Arquitectura 2025

1.1 Genealogía y Principios

LINDDUN nació en 2010 de la mano de Mina Deng, Kim Wuyts, Riccardo Scandariato, Bart Preneel y Wouter Joosen, como respuesta a la ausencia de un equivalente de STRIDE orientado específicamente a la privacidad. Su lógica estructural es análoga: cada letra del acrónimo captura un tipo de amenaza sobre la privacidad de las personas físicas, no sobre los activos de la organización. Esta distinción no es trivial: mientras que la ciberseguridad tradicional protege la confidencialidad, integridad y disponibilidad de sistemas, LINDDUN protege la **no vinculabilidad**, la **anonimidad/pseudonimidad**, la **negación plausible**, la **indetectabilidad/inobservabilidad**, la **confidencialidad**, la **conciencia del contenido** y el **cumplimiento normativo** de los individuos.^{[12][1]}

El marco se estructura en tres capas interoperables:

- Base de conocimiento de amenazas: 7 tipos, refinados en características específicas, ejemplificados en más de 120 casos primarios y casos compuestos, ahora disponibles en formatos JSON y CSV legibles por máquina para integración en herramientas automatizadas.[¹³][¹⁴]
- Árboles de amenaza: descomposición jerárquica de cada tipo en criterios de aplicabilidad, factores de impacto y ejemplos concretos.[¹⁵]
- Métodos de análisis: Go (ligero y colaborativo), Pro (sistemático sobre DFD) y Maestro (arquitectónico enriquecido).[¹⁶]

1.2 El Ciclo de Preguntas Fundamentales

Siguiendo la tradición STRIDE, LINDDUN articula cuatro preguntas que enmarcan cualquier ejercicio de modelado:[⁶]

1. ¿Qué estamos construyendo? – Diagrama de Flujo de Datos (DFD) con entidades externas, almacenes, procesos y flujos.
2. ¿Qué puede salir mal? – Aplicación sistemática de los 7 tipos de amenaza sobre cada elemento del DFD.
3. ¿Qué vamos a hacer al respecto? – Selección de Tecnologías de Mejora de la Privacidad (PETs) desde el catálogo de estrategias de mitigación.
4. ¿Hemos hecho un buen trabajo? – Evaluación retrospectiva y lecciones aprendidas.

1.3 LINDDUN en el Ecosistema de Herramientas 2025

La integración de LINDDUN en herramientas de automatización ha avanzado notablemente. OWASP ThreatDragon y SPARTA lo soportan nativamente. La herramienta PILLAR (Privacy risk Identification with LINDDUN and LLM Analysis Report), desarrollada por el FBK-Center for Cybersecurity de la Universidad de Trento en 2024–2025, integra Grandes Modelos de Lenguaje (LLMs) con el marco para automatizar la generación de DFDs, la clasificación de amenazas y la priorización de riesgos, alcanzando una precisión del 85,71% con una tasa de falsos positivos del 19,05%. Este avance sitúa a LINDDUN en el umbral de la aplicación a escala industrial.[¹⁷][¹⁸][⁴]

II. Los Siete Indicadores LINDDUN: Definición, Características y Métricas 2025–2026

Indicador 1 – Linking / Vinculación (L)

Definición canónica: Asociación de elementos de datos o acciones de usuario para aprender más sobre un individuo o grupo, incluso sin conocer su identidad.[¹⁹][²⁰]

Árbol de Amenaza y Características

El árbol de Linking se ramifica en dos nodos principales con sus respectivas hojas:[¹⁹]

- L.1 – Linked Data: vinculación mediante identificadores (email, IP, ID de usuario, dirección MAC).
- L.2 – Linkable Data: vinculación mediante combinación o análisis de datos.
- L.2.1.1 – Quasi-identifier: atributos como edad + código postal + género (combinación suficiente para singularizar a un individuo en muchas poblaciones).
- L.2.1.2 – Combining data from different individuals: listas de contactos, grafos de relaciones sociales.
- L.2.2.1 – Profiling individual: patrones derivados de datos de un solo sujeto.
- L.2.2.2 – Group profiling: perfiles de grupo que impactan a sus miembros individuales.
- L.2.2.3 – Similarity/dissimilarity profiling: inferencia por atributos compartidos o únicos.

Extensiones 2025 (GenAI)

La investigación de KU Leuven y Huawei (2026) identifica amenazas de Linking específicas para sistemas de IA Generativa:[⁴]

- Vinculación mediante señales estilísticas en outputs textuales (autoría inferida).
- Vinculación de atributos personales a través de interacciones conversacionales acumuladas.
- Linkage de datos de entrenamiento con outputs generados (inferencia de conjunto de entrenamiento).

Métricas Cuantitativas para Linking

La literatura propone un indicador de riesgo basado en la interacción entre **probabilidad de ocurrencia** e **impacto**: [²¹]

$$[\text{PIA}_L = L_L \times C_L]$$

donde ($L_L = \frac{T_n}{T_i}$) (número de interacciones en el DFD donde la amenaza L puede materializarse sobre el total de interacciones del sistema) y ($C_L = 1 + T_a$) (impacto base más el número de amenazas que la vinculación puede agravar, como Identifiabilidad y No Repudio). [²¹]

Para sistemas de hogares inteligentes (IoT), la amenaza T6 (Linkage de usuario) registra ($L = 0.371$) (13 de 35 interacciones DFD posibles) y ($C = 3$), resultando en un índice PIA de 1.11, clasificado como **alto riesgo**. [²¹]

En el marco PRASH de la Universidad de Malmö, el riesgo de vinculación adopta la forma: [²²]

$$[r_{\mu} = \alpha_{l,\mu} \times \alpha_{i,\mu}]$$

donde ($\alpha_l \in [0,1]$) es la probabilidad de éxito del ataque (calculada mediante factores DREAD: Discoverability × Reproducibility × Exploitability) y ($\alpha_i \in [0,10]$) es el impacto (función del nivel de identificabilidad y la sensibilidad contextual de los datos).

Indicadores operacionales para Linking en contexto nacional español (2025):

- Tasa de brechas con re-identificación: referenciable contra las 2.765 notificaciones AEPD 2025. [¹⁰]

- Porcentaje de sistemas con mecanismos k-anonimato o privacidad diferencial implementados.
- Número de flujos de datos cross-context sin pseudonimización en auditorías ENS.

Indicador 2 – Identifying / Identificabilidad (I)

Definición canónica: Un sujeto de datos puede ser identificado dentro de un conjunto de sujetos; los elementos de datos pueden vincularse a la identidad del sujeto, con cierta probabilidad.[²⁰]

Árbol de Amenaza y Características

- Identificación directa: procesamiento de información identificable (nombre, DNI, biometría).
 - Identificación indirecta por deducción: inferencia de identidad a partir de combinaciones de atributos.
 - Identificación por filtración: exposición accidental de datos que revelan la identidad.
 - Identificación por inferencia en ML: Membership Inference Attacks (MIA), donde un atacante determina si los datos de un individuo específico formaron parte del conjunto de entrenamiento.
- [⁴]

La identificabilidad es el umbral que convierte datos anónimos en personales, activando todo el régimen protector del RGPD. Como señala la AEPD, "cuando los datos personales pueden ser identificados, requieren medidas de seguridad aún más estrictas".[²⁰]

Extensiones 2025 (GenAI)

El CAM2 (System-to-User Leakage) del marco de amenazas GenAI de KU Leuven 2026 documenta que "incluso los modelos más capaces como GPT-4 y ChatGPT revelan información privada en contextos que los humanos no revelarían, el 39% y el 57% del tiempo, respectivamente". Las técnicas de *Attribute Inference Attacks* (AIA) permiten inferir atributos sensibles adicionales sobre un individuo a partir de respuestas del modelo que reflejan patrones memorizados.[⁴]

Métricas Cuantitativas para Identifying

El riesgo de re-identificación se cuantifica frecuentemente mediante la métrica de *k-anonimato* de Latanya Sweeney: un dataset satisface k-anonimato si cada registro es indistinguible de al menos k-1 otros registros respecto a sus quasi-identificadores. Para la evaluación del riesgo residual:[²³]

$$\text{Riesgo_Reidentificación} = 1 - \frac{k_{\text{min}}}{|S|}$$

donde (k_{min}) es el grupo de equivalencia más pequeño y ($|S|$) el tamaño total del conjunto de datos.

La descomposición cuantitativa de impacto propuesta por Wagner y Boiten opera sobre cuatro componentes:[²³]

[
$$\text{Impacto}_I = f(\text{scale}, \text{sensitivity}, \text{expectation}, \text{harm})$$

]

- Scale: proporción de personas afectadas (0-100%).
- Sensitivity: nivel de inferencia posible (escala 1-5).
- Expectation: desviación entre práctica real y expectativa razonable del usuario (0-5 dimensiones).
- Harm: daño reputacional, financiero, angustia, amenaza física y derechos (escalas mixtas ordinales).

Indicadores operacionales para España:

- Porcentaje de EIPD que incluyen análisis de k-anonimato o l-diversidad.
- Número de ataques de inferencia de membresía documentados en sistemas de IA españoles.
- Implementación de evaluaciones de re-identificación en bases de datos del sector público (art. 25 RGPD).

Indicador 3 – Non-repudiation / No Repudio (NR)

Definición canónica: Un sujeto de datos es incapaz de negar una afirmación, es decir, negar haber hecho, dicho o accedido a algo. Existen evidencias que pueden vincular al sujeto con una acción concreta.^[20]

La paradoja del no repudio reside en que, en seguridad, es un objetivo deseable (asegurar la trazabilidad de acciones); en privacidad, es una amenaza (impedir la negación plausible o el ejercicio del derecho al olvido).

Árbol de Amenaza y Características

- NR.1 – Identificabilidad como precondition: el no repudio requiere que el sujeto sea identificado.
- NR.2 – Vinculabilidad como amplificador: la vinculación de datos aumenta la dificultad de negar.
- NR.3 – Evidencia de comunicación: logs de email, metadatos de mensajería, registros de acceso.
- NR.4 – Evidencia de acción: registros de transacciones, firmas digitales, logs de votación electrónica.
- NR.5 – Evidencia de presencia: datos de geolocalización histórica, accesos físicos registrados.

Extensiones 2025 (GenAI)

Los sistemas GenAI generan una nueva dimensión del no repudio: los registros de interacciones del usuario con chatbots empresariales —incluyendo las consultas realizadas— pueden constituir evidencia de comportamiento que el usuario no puede negar, incluso cuando se trata de consultas inocentes o exploratorias. El marco LIINE4DU de la AEPD reformula esta amenaza como "la capacidad de atribuir una característica o actividad al interesado cuando esto implica un impacto para sus derechos y libertades fundamentales".^{[6][4]}

Métricas Cuantitativas para Non-repudiation

Se propone un indicador de exposición al no repudio (**NERMI** — Non-repudiation Exposure Risk Metric Index) derivado del análisis de interacciones DFD:^[21]

$$\text{NERMI} = \frac{\sum_{i=1}^n w_i \cdot e_i}{n \cdot \text{total_flows}}$$

donde (e_i) es la presencia de evidencia persistente en el flujo i (binario: 0/1) y (w_i) es el peso por tipo de evidencia (logs de acción = 1.0; metadatos = 0.7; timestamps = 0.5).

La aplicación del CVSS 4.0 adaptada a privacidad permite valorar las métricas de impacto en confidencialidad (VC) y en la esfera individual del afectado.^[24]

Indicadores operacionales para España:

- Porcentaje de sistemas críticos con logs inmutables sin mecanismo de anonimización programada.
- Número de resoluciones AEPD invocando violación del derecho al olvido por no repudio técnico.
- Cumplimiento del ENS (Esquema Nacional de Seguridad) respecto a retención y cifrado de logs de auditoría.

Indicador 4 – Detecting / Detección (D)

Definición canónica: Deducir la implicación de un sujeto de datos en una actividad a través de la observación, incluso sin poder identificarlo. La detección es distinta de la identificación: se puede detectar *que alguien* usa un servicio sin saber *quién* es.^{[19][20]}

Árbol de Amenaza y Características

- D.1 – Detección de presencia: inferir que un individuo (no identificado) usa un servicio o está en un lugar.
- D.2 – Detección de comportamiento: deducir patrones de actividad (horarios, frecuencias).
- D.3 – Detección de estado: inferir condiciones personales (salud, estado emocional) por observación indirecta.
- D.4 – Traffic analysis: análisis de tráfico de red que revela comunicaciones aunque el contenido esté cifrado.
- D.5 – Side-channel detection: información filtrada por consumo eléctrico, timing de respuestas, patrones de señal RF.^[22]

El ENISA Threat Landscape 2025 documenta que los ataques de tipo *lamphone* —recuperación de sonido mediante variaciones en la intensidad lumínica de una bombilla— representan una realización extrema de las amenazas de detección por canal lateral.^[25]

Extensiones 2025 (GenAI e IoT)

El 85% de los dispositivos infectados en botnets en España en 2025 eran dispositivos IoT. Cada dispositivo conectado constituye un potencial vector de detección: desde termostatos que revelan patrones de ocupación hasta aspiradoras robóticas que generan mapas de planta de los hogares. La amenaza de inferencia por actividad de dispositivos IoT se clasifica como detectabilidad en el árbol LINDDUN y adquiere dimensiones territoriales nacionales cuando afecta a infraestructuras críticas.^{[11][22]}

Métricas Cuantitativas para Detecting

El riesgo de detección en infraestructuras IoT aplica la fórmula PRASH adaptada:[²²]

$$\alpha_{l,D} = P(\text{Discoverability}) \times P(\text{Reproducibility}) \times P(\text{Exploitability})$$

Donde cada factor toma valores en {Alto: 0.7–1.0, Medio: 0.4–0.69, Bajo: 0.0–0.39} según criterios DREAD calibrados para detección por observación pasiva versus activa.

Para la detección de presencia en servicios digitales, se propone el **Detection Surface Index (DSI)**:

$$DSI = \frac{n_{\text{observable_signals}}}{n_{\text{total_signals}}} \times \text{Persistence}_{[0,1]}$$

donde Persistence es 1 si los datos se retienen indefinidamente y decrece con la aplicación de técnicas de privacidad diferencial o borrado programado.

Indicadores operacionales para España:

- Porcentaje de operadores esenciales con monitorización de tráfico cifrado sin análisis de metadatos (cumplimiento NIS2).
- INCIBE 2025: 401 incidentes en operadores esenciales, con Banca (34%) y Transporte (14%) como sectores más afectados.[¹¹]
- Número de sistemas con implementación de *Oblivious RAM* o *Private Information Retrieval* para protección contra detectabilidad en accesos a bases de datos.

Indicador 5 - Data Disclosure / Divulgación de Información (DD)

Definición canónica: Recopilación, almacenamiento, procesamiento o compartición/transferencia de datos personales en exceso. Es la amenaza más directamente vinculada a los principios de minimización de datos y limitación de la finalidad del RGPD (Art. 5.1.b y 5.1.c).[⁶][²⁰]

Árbol de Amenaza y Características

La estructura del árbol de Data Disclosure comprende:[²⁶][¹⁹]

- DD.1 – Excessive data collection: recogida de datos más allá de lo necesario para la finalidad declarada.
- DD.1.1: datos innecesarios para el propósito primario.
- DD.1.2: datos recopilados para finalidades futuras indefinidas (función creep).
- DD.1.3 (nuevo, 2025): representaciones intermedias reversibles en sistemas de ML (embeddings, activaciones, gradientes) que constituyen divulgación implícita de datos de entrenamiento.[⁴]
- DD.2 – Excessive data storage: retención más allá de la necesidad operativa.
- DD.3 – Excessive data processing: procesamiento sin base legitimadora adecuada.
- DD.3.5 (nuevo, 2025): outputs alucinados (fabrication) que revelan datos reales o plausiblemente reales de terceros presentes en el entrenamiento.[⁴]
- DD.4 – Excessive data sharing: transferencia a terceros sin justificación proporcional.

Extensiones 2025 (GenAI)

El CAM6 (Residual Privacy Leakage) del marco GenAI de KU Leuven 2026 documenta que en arquitecturas de aprendizaje federado, los gradientes y pérdidas producidas durante el backpropagation pueden filtrar información sobre registros individuales. Los embeddings vectoriales pueden invertirse para recuperar texto original, constituyendo una forma de divulgación de datos de entrenamiento que no existía en los sistemas tradicionales. Esto afecta directamente a sistemas de IA desarrollados o desplegados en España bajo el mandato del AI Act.[⁴]

Métricas Cuantitativas para Data Disclosure

El índice de exposición a divulgación puede computarse como función de la sensibilidad de los datos y la extensión del procesamiento:[²³]

$$\text{DD_Score} = \sum_{d \in D} s(d) \times p(d) \times r(d)$$

donde:

- ($s(d)$): sensibilidad del dato (categoría RGPD: especial = 1.0, personal ordinario = 0.5, seudonimizado = 0.2).
- ($p(d)$): probabilidad de que el dato sea procesado sin base legitimadora ($p \in [0,1]$).
- ($r(d)$): alcance de la divulgación (número de destinatarios normalizados sobre el máximo del sistema).

En el estudio de Alalade et al. (Carleton University, 2024), la amenaza de Data Leakage (T8, equivalente a DD) registra ($L = 0.314$) y ($C = 5$), con un PIA = 1.57 y clasificación de **alto riesgo**. [²¹]

Indicadores operacionales para España:

- Las brechas relacionadas con ransomware e intrusiones en CRMs con exfiltración masiva de datos personales fueron las que afectaron a mayor número de personas en 2025.[¹⁰]
- El 40% de las sanciones AEPD en 2024 se relacionaron con internet y videovigilancia.[²⁷]
- Número de EIPDs con análisis explícito de minimización de datos por cada categoría de tratamiento (indicador de madurez RGPD del Observatorio de la Privacidad, ISMS Forum 2026).[²⁸]

Indicador 6 – Unawareness & Unintervenability / Desconocimiento e Imposibilidad de Intervención (U)

Definición canónica: Informar, involucrar o empoderar a los individuos en el tratamiento de sus datos personales de manera insuficiente. Este indicador captura la dimensión **subjetiva** de la privacidad: no es suficiente que el sistema sea técnicamente seguro si el interesado no puede comprenderlo, controlarlo ni ejercer sus derechos sobre él.^{[19][20]}

Árbol de Amenaza y Características

- U.1 – Insufficient notice: información opaca, incompleta o incomprensible sobre el tratamiento.
- U.2 – Insufficient involvement: el interesado no puede verificar, acceder ni rectificar sus datos.
- U.3 – Insufficient empowerment: el interesado no puede revocar consentimiento ni oponerse de forma efectiva.
- U.3 (nuevo, 2025) – Interference with decision-making: sistemas de IA que distorsionan la capacidad del interesado de tomar decisiones informadas sobre el tratamiento de sus propios datos.^[4]
- U.4 – Context collapse: el interesado no comprende cómo sus datos fluyen a través de sistemas complejos o entre organizaciones.

La AEPD adopta en LIINE4DU la denominación "Desconocimiento y falta de capacidad para intervenir" y la define como "demostrar de manera insuficiente el cumplimiento o informar, involucrar o empoderar a los interesados de manera insuficiente".^[6]

Extensiones 2025 (AI Act y Dark Patterns)

El AI Act, en vigor en sus disposiciones sobre prácticas prohibidas desde febrero de 2025, prohíbe explícitamente los sistemas que "empleen técnicas subliminales o deliberadamente manipuladoras o engañosas" que causen daño significativo, reforzando la dimensión normativa del indicador U.3. España ha sido uno de los primeros países de la UE en transponer estas prohibiciones con multas de hasta 38 millones de euros o el 7% de la facturación global. La integración de estos requisitos en el árbol de amenazas Unawareness es un avance directo de la investigación LINDDUN de 2025.^{[29][30][4]}

Métricas Cuantitativas para Unawareness

El **Privacy Notice Effectiveness Index (PNEI)** propuesto en la literatura reciente evalúa la calidad de la información proporcionada:^[31]

$$\left[\begin{aligned} \text{PNEI} &= \frac{\text{Dimensiones_cumplidas}}{\text{Total_dimensiones_RGPD}} \times \text{Comprensibilidad}_{\{0,1\}} \\ \end{aligned} \right]$$

Las dimensiones incluyen: identidad del responsable, finalidades, base legitimadora, destinatarios, plazos de retención, derechos del interesado y existencia de decisiones automatizadas (Arts. 13-14 RGPD).

Para la intervenibilidad, se propone el **User Control Score (UCS)**:

$$\left[\text{UCS} = \frac{\sum_{r \in \text{Derechos}} \text{efectividad}(r)}{|\text{Derechos}|} \right]$$

donde efectividad(r) evalúa el plazo real de respuesta (1 si ≤ 30 días, penalizado proporcionalmente), la ausencia de obstáculos procesales y la completitud de la respuesta.

Indicadores operacionales para España:

- La AEPD ha emitido más de 200 millones de comunicaciones a personas afectadas por brechas de alto riesgo en 2025, activando el deber de transparencia activa.^[10]
- El Indicador de Madurez en RGPD del Observatorio de la Privacidad (ISMS Forum, 2026) incluye dimensiones de transparencia e intervenibilidad.^[28]
- Tasa de solicitudes de ejercicio de derechos ARCO+ respondidas en plazo: indicador clave de U.2/U.3.

Indicador 7 – Non-compliance / Incumplimiento (NC)

Definición canónica: Desviación de las mejores prácticas, estándares y legislación en materia de seguridad y protección de datos. LINDDUN limita el alcance del incumplimiento a aquel que deriva directamente de los seis tipos de amenaza anteriores, evitando convertirlo en un cajón de sastre normativo.^[20]^[19]

Árbol de Amenaza y Características

- NC.1 – Incumplimiento normativo:
 - NC.1.1: RGPD (principios, derechos, obligaciones de responsables y encargados).
 - NC.1.2: Legislación sectorial (sanitaria, financiera, telecomunicaciones).
 - NC.1.3 (nuevo, 2025): Reglamento de IA Europeo (AI Act) — Artículo 5 prácticas prohibidas, Artículo 10 gobernanza de datos, Artículo 13 transparencia.^[29]^[4]
- NC.2 – Incumplimiento de estándares técnicos:
 - NC.2.1: ISO/IEC 27001 (sistemas de gestión de seguridad de la información).
 - NC.2.2: ISO/IEC 27701 (extensión de privacidad para ISO 27001).
 - NC.4.2 (nuevo, 2025): Estándares específicos de IA (ISO/IEC 42001, ISO/IEC 27564).^[32]
- NC.3 – Incumplimiento de mejores prácticas: ausencia de Privacy by Design, evaluaciones de impacto omitidas, contratos de encargado deficientes.

La AEPD ha tomado una decisión metodológicamente significativa en LIINE4DU: **eliminar el Non-compliance como categoría**, argumentando que el tratamiento no conforme con la normativa directamente no puede implementarse, y que la categoría es "demasiado genérica para ser útil en el contexto de las EIPDs". En su lugar, las amenazas de incumplimiento quedan absorbidas en las categorías de Data Disclosure, Unawareness y las nuevas categorías de Data Breach y Deception.^[6]

Extensiones 2025: Non-compliance ante AI Act e IA Agéntica

El XVIII Foro de la Privacidad de ISMS Forum (febrero 2026) identificó como principal desafío la "convergencia regulatoria" entre RGPD, AI Act y el paquete Ómnibus Digital, y la "IA agéntica" como nuevo vector de riesgo de incumplimiento. Los sistemas de IA agéntica —capaces de actuar

autónomamente en nombre del usuario— introducen cadenas de responsabilidad difusas donde el incumplimiento puede ser difícil de atribuir a un responsable del tratamiento específico.^[28]

Métricas Cuantitativas para Non-compliance

El **Compliance Gap Index (CGI)** evalúa la brecha entre controles implementados y controles requeridos:^[33]

$$\text{CGI} = 1 - \frac{\sum_{c \in C_{\text{impl}}} w_c}{\sum_{c \in C_{\text{req}}} w_c}$$

donde (w_c) es el peso de cada control según su criticidad (crítico = 1.0, importante = 0.7, básico = 0.3) y los conjuntos (C_{impl}) y (C_{req}) representan los controles implementados y requeridos respectivamente.

El CVSS 4.0, en su grupo de métricas ambientales, permite parametrizar el impacto regulatorio en las evaluaciones de vulnerabilidad vinculadas al incumplimiento.^[24]

Indicadores operacionales para España:

- Solo 11 de las 2.765 brechas notificadas en 2025 se trasladaron para investigación adicional por indicios de falta de diligencia.^[34]
- La AEPD publicó en diciembre 2025 (a través de AESIA) guías para sistemas de IA de alto riesgo con 16 documentos técnicos y plantillas de cumplimiento.^[35]
- El Plan de Actuación AEPD 2026 incluye 32 objetivos y 115 acciones, con énfasis en el Laboratorio de Privacidad y la colaboración con universidades.^{[36][37]}

III. LINDDUN Maestro: El Marco Arquitectónico de Nueva Generación (2025)

3.1 Fundamento y Diferenciación

LINDDUN Maestro, publicado en *Software and Systems Modeling* en noviembre de 2025, representa la evolución más ambiciosa del marco. Su premisa fundamental es que el DFD clásico —suficiente para LINDDUN Pro— resulta insuficiente para capturar la complejidad de sistemas distribuidos modernos (microservicios, arquitecturas cloud-native, IA agéntica). Maestro extiende el DFD con **seis vistas complementarias**:^{[38][5][9]}

Vista	Stakeholders Primarios	Relevancia para Indicadores LINDDUN
Communication view	Operadores de red/sistema	Detecting, Non-repudiation
Application view	Desarrolladores, ingenieros	Data Disclosure, Linking
Data view	Ingenieros de datos, DPOs	Linking, Identifying, Data Disclosure
Organizational view	Directores, responsables legales	Non-compliance, Unawareness
Infrastructure view	Administradores de sistemas	Detecting, Data Disclosure
Operational view	Equipos de operaciones/SRE	Non-repudiation, Detecting

Cada vista es enriquecida por los miembros del equipo desde su perspectiva específica, permitiendo una elicitación de amenazas más precisa y contextualizada. El equipo de KU Leuven está desarrollando herramientas automatizadas específicas para Maestro.^[38]

3.2 Tablas de Búsqueda (Lookup Tables) como Indicadores

Una contribución central de Maestro son las **lookup tables** por vista, que especifican tipos de enriquecimiento útiles para orientar evaluaciones en profundidad. Estas tablas funcionan como indicadores de segunda generación: en lugar de preguntar "¿existe la amenaza X?", preguntan "¿qué propiedades de esta vista hacen más probable la amenaza X?". Por ejemplo:^[38]

- En la *Communication view*: patrones de comunicación persistente → mayor riesgo de Non-repudiation.
- En la *Data view*: tipos de datos con quasi-identificadores → mayor riesgo de Linking e Identifying.
- En la *Organizational view*: ausencia de DPO formal → mayor riesgo de Non-compliance y Unawareness.

IV. El Marco LIINE4DU: La Adaptación Española de LINDDUN

4.1 Génesis y Motivación

La AEPD publicó en octubre de 2024 la nota técnica introductoria de LIINE4DU 1.0 (Likage, Identifying, Inaccuracy, Non-repudiation, Exclusion, Data Breach, Deception, Unawareness/Unintervenability). El punto de partida es honesto hasta la irreverencia constructiva: "si bien LINDDUN es un marco sólido y maduro, la AEPD ha encontrado algunos inconvenientes al usarlo específicamente para ayudar con el cumplimiento del RGPD y realizar una EIPD".^{[39][40][6]}

Los inconvenientes identificados son tres: (1) LINDDUN no siempre se alinea directamente con los principios y requisitos del RGPD; (2) su enfoque es predominantemente técnico y puede no abordar plenamente los aspectos organizativos y procedimentales; (3) la integración de sus resultados en una EIPD puede requerir esfuerzo adicional.^[6]

4.2 Arquitectura de Amenazas LIINE4DU

Las diez categorías de LIINE4DU —que conservan la lógica del DFD de LINDDUN y sus cuatro preguntas fundamentales— se organizan en dos grupos:^[6]

Grupo A – Amenazas sobre derechos y libertades individuales (pueden implicar o no incumplimiento RGPD):

Categoría	Descripción Técnica	Equivalencia LINDDUN
Linking / Vinculación	Relacionar datos/actividades para obtener más información	Linking (L)
Identifying / Identificación	Conocer la identidad directa o indirectamente	Identifying (I)
Inaccuracy / Inexactitud (nueva)	Uso de datos obsoletos, erróneos, sesgados o incompletos	— (nueva categoría)
Non-repudiation / No repudio	Atribuir características/actividades con impacto en derechos	Non-repudiation (NR)
Exclusion / Exclusión (nueva)	Obstaculizar participación física o digital del interesado	— (nueva categoría)
Detecting / Detección	Deducir implicación a través de la observación	Detecting (D)
Unawareness & Unintervenability	Desconocimiento e imposibilidad de intervención	Unawareness (U)

Grupo B – Amenazas con incumplimiento directo del RGPD (implican violación normativa):

Categoría	Descripción Técnica	Equivalencia LINDDUN
Data Breach / Brecha de datos (nueva)	Destrucción, pérdida, acceso no autorizado a datos	Parcialmente DD + NC
Deception / Engaño (nueva)	Manipulación intencional del interesado	— (nueva categoría)
Data Disclosure / Divulgación	Recopilación, almacenamiento o transferencia excesiva	Data Disclosure (DD)

La amenaza de **Inaccuracy** es especialmente relevante en España dado el alto uso de sistemas de puntuación crediticia y perfilado automatizado: los datos inexactos pueden llevar a decisiones discriminatorias que el RGPD prohíbe (Art. 22).^[41]

4.3 Aplicación a las EIPDs Españolas

El modelado de amenazas LIINE4DU no sustituye a la EIPD pero enriquece tres fases clave:^[6]

- 1. Identificación de riesgos:** ampliando el conjunto mínimo de escenarios de riesgo establecido en la guía de gestión del riesgo de la AEPD.
- 2. Evaluación de impacto y probabilidad:** mediante escenarios más realistas derivados del árbol de amenazas.
- 3. Selección de medidas de mitigación:** orientando la elección entre el amplio catálogo de salvaguardas disponibles hacia las más pertinentes para cada amenaza específica.

V. Métricas Integradas: El Sistema de Puntuación LINDDUN-PIA

5.1 La Fórmula Base de Riesgo de Privacidad

La fórmula canónica para el Análisis de Impacto sobre la Privacidad (PIA/EIPD) con indicadores LINDDUN es:[^21]

$$\boxed{\text{PIA} = L \times C}$$

donde:

$$L = \frac{T_n}{T_i}, \quad C = I + T_a$$

- (T_n): número de interacciones en el DFD donde la amenaza puede materializarse.
- (T_i): total de interacciones en el sistema modelado.
- (I): impacto base de la amenaza (fijado en 1 por defecto).
- (T_a): número de otras amenazas LINDDUN que esta amenaza puede agravar (efecto cascada).

Esta fórmula, aplicada por Alalade et al. (Carleton University) a sistemas IoT, produce los siguientes rangos de priorización:[^21]

Rango PIA	Prioridad	Acción Recomendada
$PIA \geq 1.5$	Alto	Mitigación inmediata obligatoria
$0.5 \leq PIA < 1.5$	Medio	Mitigación planificada con seguimiento
$PIA < 0.5$	Bajo	Monitorización periódica

5.2 El Modelo de Riesgo Multidimensional PRASH

Para sistemas con mayor complejidad arquitectónica (IoT, smart cities, infraestructuras críticas), el modelo PRASH de la Universidad de Malmö ofrece una parametrización más granular:[^22]

$$r_{\mu} = \alpha_{\{l, \mu\}} \times \alpha_{\{i, \mu\}}$$

Cálculo de (α_1) (probabilidad de éxito del ataque) mediante factores DREAD:

$$\alpha_1 = P(\text{Descubribilidad}) \times P(\text{Reproducibilidad}) \times P(\text{Impacto})$$

```
text{Explotabilidad})
]
```

Tabla de calibración DREAD para privacidad:

Factor	Alto (0.7–1.0)	Medio (0.4–0.69)	Bajo (0.0–0.39)
Descubribilidad	Función conocida, exploits publicados, datos accesibles	Área poco frecuentada, algo de reflexión necesaria	Vulnerabilidad oscura, información no pública
Reproducibilidad	Siempre funciona, sin privilegios	Privilegios básicos o timing requeridos	Acceso físico o privilegios elevados
Explotabilidad	Novato puede explotar rápidamente	Programador especializado necesario	Experto con equipamiento especial

Con ajuste por poder del agente de amenaza (**tap**, Threat Agent Power):

```
[
\alpha_{l,ta} = \frac{e^{\{(tap - \alpha_l)\}}}{1 + e^{\{(tap - \alpha_l)\}}}
]
```

Cálculo de (α_i) (impacto): función del nivel de identificación y la sensibilidad contextual:

```
[
\alpha_i = f(\text{identification_level}, \text{data_context_sensitivity})
]
```

Escala de severidad del riesgo:[²²]

Rango (r_{μ})	Descripción
7.0–10.0	Fácilmente explotable; compromete gravemente la privacidad
4.0–6.9	Difícil de explotar pero amenaza la privacidad
0.1–3.9	Improbable o consecuencias mínimas
0.0	Sin riesgo

5.3 La Descomposición Científica del Riesgo (Wagner & Boiten)

La propuesta de Wagner y Boiten (De Montfort University, ampliamente referenciada en 2025) ofrece la descomposición más rigurosa del riesgo de privacidad:[²³]

Impacto descompuesto en cuatro componentes:

```
[
\text{Impacto} = \phi(\text{escala}, \text{sensibilidad}, \text{expectativa}, \text{daño})
]
```


- Escala: proporción de personas afectadas (0–100% de la población expuesta).
- Sensibilidad: nivel de información revelada, medible en bits mediante teoría de la información.
- Expectativa: número de dimensiones en que la realidad difiere de la expectativa razonable del interesado (operacionalizable mediante la taxonomía de Solove).
- Daño: financiero, reputacional, angustia psicológica, amenaza a la vida, vulneración de derechos (cada uno en su escala propia).

Probabilidad descompuesta en tres aspectos:

$$P_{\{\text{violación}\}} = P(\text{ataque}) \times P(\text{efecto adverso}) \times P(\text{explotabilidad})$$

La recomendación metodológica es combinar estas métricas mediante **radar plots** en lugar de sumas o productos de escalas ordinales, dado que la adición de escalas Likert crea una falsa sensación de precisión.^[23]

5.4 Tabla Comparativa de Métricas por Indicador

Indicador LINDDUN	Métrica Principal	Fórmula Clave	Fuente
Linking	Privacy Impact Assessment	$(\text{PIA}_L = \frac{T_n}{T_i} \times (1 + T_a))$	Alalade et al. 2024 ^[21]
Identifying	Re-identification Risk	$(1 - k_{\min}) /$	S
Non-repudiation	NERMI Index	$(\sum w_i \cdot e_i / n_{\{\text{flows}\}})$	Derivado LINDDUN PRO ^[26]
Detecting	Detection Surface Index	$((n_{\{\text{obs_signals}\}} / n_{\{\text{total}\}}) \times \text{Persistence})$	PRASH adaptado ^[22]
Data Disclosure	DD Score	$(\sum s(d) \times p(d) \times r(d))$	Wagner & Boiten ^[23]
Unawareness	PNEI + User Control Score	$(\text{UCS} = \sum \text{efect}(r) /$	Derechos
Non-compliance	Compliance Gap Index	$(1 - \sum w_{\{c, \text{impl}\}} / \sum w_{\{c, \text{req}\}})$	CVSS 4.0 adaptado ^[33] [24]

VI. El Paisaje Español de Privacidad 2025–2026: Indicadores Territoriales

6.1 Datos de Referencia Nacionales

El año 2025 ha sido un punto de inflexión en la madurez de la protección de datos en España:

- 2.765 notificaciones de brechas de datos a la AEPD — máximo histórico. Distribución: 80% sector privado, 20% sector público.[³⁴][¹⁰]
- 122.223 incidentes de ciberseguridad gestionados por INCIBE, un 26% más que en 2024. Desglose: Malware 55.411 (incluyendo 392 ransomware), Fraude online 45.445, Phishing 25.133, Robo de información 3.849.[¹¹]
- 85% de dispositivos en botnets correspondían a IoT doméstico.[¹¹]
- 401 incidentes en operadores esenciales, con Banca (34%), Transporte (14%) y Energía (8%) como sectores principales.[¹¹]
- El ransomware y las intrusiones en CRMs con exfiltración masiva constituyeron las brechas de mayor alcance poblacional.[¹⁰]

6.2 Marco Regulatorio Activo 2025–2026

España opera en 2025–2026 en el ecosistema normativo más denso de su historia en materia de privacidad y ciberseguridad:[⁴²]

- RGPD (Reglamento 2016/679): plenamente aplicable, con énfasis AEPD en Arts. 25, 32 y 35.
- AI Act (Reglamento 2024/1689): prácticas prohibidas en vigor desde febrero 2025; sistemas de alto riesgo sujetos a requisitos desde agosto 2026.[²⁹]
- NIS2 (Directiva 2022/2555): transpuesta en España, con nuevas obligaciones para operadores esenciales e importantes.
- Paquete Ómnibus Digital: en proceso de adopción, unificando ePrivacy, Ley de Datos y regulación de plataformas.[⁴²]
- eIDAS2: nuevo marco de identidad digital europea, con implicaciones directas para los indicadores de Identifying y Non-repudiation.
- Legislación española de IA: multas de hasta 38 millones de euros o el 7% de facturación global por incumplimiento del AI Act.[³⁰]

6.3 Indicadores AEPD 2026: Plan de Actuación

El Plan de Actuación AEPD 2026 define 32 objetivos operativos y 115 acciones, con especial relevancia para el marco LINDDUN/LIINE4DU:[³⁷][³⁶]

- Laboratorio de Privacidad: colaboración con universidades y centros de investigación para desarrollar herramientas de análisis de amenazas (alineado con el desarrollo de LIINE4DU hacia árboles de amenazas específicos).[³⁶]
- Herramientas de IA en procesos internos: la AEPD aplica los indicadores que ella misma regula.
- Indicador de Madurez en RGPD: desarrollado por el Observatorio de la Privacidad de ISMS Forum 2026.[²⁸]
- Privacy Breach Management: proyecto específico de gestión avanzada de brechas, directamente relacionado con el indicador Data Breach de LIINE4DU.[²⁸]

6.4 Análisis Comparativo Internacional

Dimensión	España (AEPD/LIINE4DU)	Europa (LINDDUN + ENISA)	Global (NIST + LINDDUN)
Marco de referencia	LIINE4DU 1.0 (RGPD- centrado)	LINDDUN Pro/Maestro + ETL 2025	NIST Privacy Framework + LINDDUN
Énfasis en derechos	Derechos y libertades individuales	Privacidad técnica y arquitectónica	Gestión del riesgo de privacidad
Incidentes 2024–2025	2.765 brechas, 122K incidentes ^{[10][11]}	~4.900 incidentes (ENISA ETL) ^[25]	No centralizado
Ransomware	81.1% de cibercrimen UE ^[43]	Predominante en extorsión	Variable por jurisdicción
Innovación regulatoria	AI Act + Ómnibus + eIDAS ^[42]	AI Act como marco common	Marco fragmentado (EE.UU.)
Herramientas automatizadas	LIINE4DU (en desarrollo de árboles)	PILLAR, OWASP ThreatDragon ^[17]	NIST PF + CVSS + MITRE ATT&CK

El ENISA Threat Landscape 2025 analiza 4.875 incidentes en el período julio 2024–junio 2025, con datos de exfiltración (30.2%), el 81.1% del cibercrimen europeo relacionado con ransomware. La exfiltración masiva de datos es el vector que activa simultáneamente los indicadores de Data Disclosure, Identifying y Non-compliance de LINDDUN/LIINE4DU.^{[43][25]}

VII. LINDDUN en la Frontera: Inteligencia Artificial Generativa y Sistemas Agénticos

7.1 El Marco GenAI de KU Leuven y Huawei (2026)

La investigación publicada en arXiv en marzo de 2026 por DistriNet (KU Leuven) y el Huawei Heisenberg Research Center de Múnich introduce el primer marco de modelado de amenazas de privacidad específico para sistemas de IA Generativa, construido sobre LINDDUN. El marco afecta a tres de los siete tipos de amenaza y añade 100 nuevos ejemplos.^[4]

Los seis **Modelos de Atacante Comunes (CAMs)** identificados y su mapping LINDDUN:^[4]

CAM	Descripción	Indicadores LINDDUN Activados
CAM1: User-to-System Leakage	El sistema extrae información sensible de las consultas del usuario	Linking, Identifying, Data Disclosure
CAM2: System-to-User Leakage	El usuario extrae datos de entrenamiento del modelo	Identifying, Data Disclosure, Non-repudiation
CAM3: PT-to-FT Leakage	El fine-tuner reconstruye datos de pre-entrenamiento	Identifying, Data Disclosure
CAM4: System-to-Agent Leakage	Modelo comprometido expone datos a agentes externos	Data Disclosure, Detecting
CAM5: Agent-to-System Leakage	Agente exfiltra datos del usuario a sistemas externos	Linking, Data Disclosure, Non-compliance
CAM6: Residual Privacy Leakage	Cómputos intermedios (embeddings, gradientes) revelan datos	Identifying, Data Disclosure

7.2 Tres Nuevas Dimensiones de Amenaza

El análisis sistemático de 58 artículos sobre privacidad en GenAI identifica tres dimensiones de amenaza sin precedentes en LINDDUN clásico:[^4]

5.

Estocasticidad: los outputs no deterministas del modelo pueden revelar datos de entrenamiento de forma impredecible, dificultando tanto la evaluación del riesgo como la imputación de responsabilidad (afecta a Data Disclosure y Non-compliance).

6.

Alfabetización en IA (AI Literacy): los usuarios no tienen las herramientas conceptuales para comprender los riesgos de privacidad inherentes a los sistemas GenAI, amplificando la amenaza Unawareness hasta niveles sistémicos.

7.

Manipulación: los sistemas GenAI pueden ser explotados para engañar a los usuarios respecto al tratamiento de sus datos, activando una nueva forma del indicador Unawareness (U.3: interferencia con la toma de decisiones).[^4]

Estocasticidad: los outputs no deterministas del modelo pueden revelar datos de entrenamiento de forma impredecible, dificultando tanto la evaluación del riesgo como la imputación de responsabilidad (afecta a Data Disclosure y Non-compliance).

Alfabetización en IA (AI Literacy): los usuarios no tienen las herramientas conceptuales para comprender los riesgos de privacidad inherentes a los sistemas GenAI, amplificando la amenaza Unawareness hasta niveles sistémicos.

Manipulación: los sistemas GenAI pueden ser explotados para engañar a los usuarios respecto al tratamiento de sus datos, activando una nueva forma del indicador Unawareness (U.3: interferencia con la toma de decisiones).^[4]

7.3 Validación Empírica

El marco GenAI fue validado sobre dos casos de estudio:^[4]

- **HR Chatbot** (caso bottom-up): 21 amenazas de privacidad identificadas; precisión del método 85.71%.
- **Agentic AI Assistant** (caso de validación): aplicación del marco a un sistema multi-agente más complejo, confirmando la cobertura y consistencia de la taxonomía.

VIII. Tecnologías de Mitigación (PETs) por Indicador

LINDDUN articula las contramedidas como **Tecnologías de Mejora de la Privacidad (PETs)** mapeadas sobre cada indicador. La tabla siguiente sintetiza las mitigaciones más relevantes para el contexto español 2025–2026:^[44]

Indicador	PETs Primarias	Estándares Aplicables
Linking	K-anonimato, l-diversidad, t-closeness; privacidad diferencial; pseudonimización	ISO/IEC 20889, NIST SP 800-188
Identifying	Anonimización, tokenización, cifrado homomórfico; técnicas anti-reidentificación	ENISA Pseudonymisation Guidelines
Non-repudiation	Deniable encryption; borrado criptográfico; logs con retención limitada	ENS Nivel Alto (España)
Detecting	Onion routing (Tor); Private Information Retrieval; Oblivious RAM; cifrado de metadatos	RFC 8484 (DNS over HTTPS)
Data Disclosure	Minimización por diseño; federated learning; cómputo seguro multipartito; datos sintéticos	Art. 25 RGPD; ISO/IEC 29101
Unawareness	Interfaces de consentimiento granular; dashboards de privacidad; notificaciones proactivas	Art. 12-14 RGPD; W3C P3P
Non-compliance	Privacy by Design; DPIAs; auditorías continuas; gestión de cumplimiento AI Act	ISO/IEC 27701; ENS; AI Act Art. 9

IX. Análisis Crítico y Prospectiva 2026–2028

9.1 Fortalezas del Marco LINDDUN en 2025

- Madurez y extensibilidad: 15 años de desarrollo continuo, base de conocimiento en formatos legibles por máquina, capacidad de extensión demostrada para GenAI.^{[45][13]}
- Reconocimiento institucional: NIST, ISO 27550, EDPS Opinion on Privacy by Design, AEPD (LIINE4DU).^{[2][3][6]}
- Automatización emergente: PILLAR (85.71% de precisión), integración en OWASP ThreatDragon, soporte en SPARTA.^{[17][4]}
- Convergencia regulatoria: el mapping directo a RGPD Art. 25, AI Act y NIS2 proporciona valor jurídico inmediato.^[1]

9.2 Limitaciones y Desafíos

- Ausencia de métricas cuantitativas nativas: LINDDUN "usa puntuaciones de riesgo pero no especifica cómo deben determinarse". Esta laguna obliga a recurrir a marcos externos (CVSS, PRASH, fórmulas ad hoc).^[23]
- Escalabilidad: el número de amenazas crece exponencialmente con el tamaño del DFD, problema que Maestro mitiga parcialmente mediante vistas especializadas.^[46]
- Brecha entre amenaza técnica y daño individual: LINDDUN identifica amenazas arquitectónicas, pero la cuantificación del daño real al interesado requiere marcos complementarios como la taxonomía de Solove.^[23]
- Sistemas GenAI y agénticos: aunque el marco de 2026 los aborda, la naturaleza estocástica e interpretativa de los LLMs desafía la lógica determinista del DFD clásico.

9.3 Tendencias 2026–2028

8. Automatización total del análisis: el éxito de PILLAR anticipa herramientas que generarán DFDs, aplicarán árboles de amenaza y priorizarán riesgos con supervisión humana mínima.
9. Certificación LINDDUN: la adopción en ISO 27550 y el reconocimiento NIST abre la vía hacia esquemas de certificación de sistemas basados en LINDDUN, con implicaciones directas para la contratación pública española bajo ENS.
10. Convergencia LINDDUN-AI Act: el artículo 9 del AI Act (sistema de gestión de riesgos) y el artículo 10 (gobernanza de datos) tienen correspondencia directa con los indicadores LINDDUN; su integración formal es predecible en las guías técnicas de 2026.
11. LIINE4DU 2.0: la AEPD trabaja en los árboles de amenaza completos para sus 10 categorías, incluyendo el análisis explícito de impactos en derechos y libertades y las estrategias de mitigación correspondientes.^[6]
12. Métricas nacionales de privacidad: el Indicador de Madurez en RGPD de ISMS Forum podría convertirse en referencia de benchmarking para organizaciones españolas, análogo al CMMI para ciberseguridad.^[28]

X. Recomendaciones para Organizaciones Españolas

Las siguientes recomendaciones se articulan alrededor del ciclo de análisis LINDDUN/LIINE4DU y los imperativos regulatorios 2025–2026:

Dimensión Operativa (90 días):

- Adoptar LIINE4DU como marco de amenazas en las EIPDs, incorporando las nuevas categorías de Inaccuracy y Deception en los análisis de tratamientos de alto riesgo.
- Implementar métricas cuantitativas de Linking e Identifying (k-anonimato mínimo k=5 para datos de salud y financieros) como indicadores KPI de privacidad del cuadro de mando.
- Documentar los flujos de datos en DFDs para todos los tratamientos de categorías especiales (Art. 9 RGPD), habilitando el análisis posterior con LINDDUN Pro o Maestro.

Dimensión Táctica (6 meses):

- Formar equipos multidisciplinares CISO + DPO + arquitecto + jurídico para aplicar LINDDUN Maestro en sistemas críticos, siguiendo la recomendación del marco.^[47]
- Integrar el análisis de amenazas GenAI (CAMs 1–6) en las evaluaciones de riesgo de sistemas de IA Generativa desplegados o en desarrollo.
- Establecer un Compliance Gap Index (CGI) por sistema de información, con umbrales de alerta para AI Act, RGPD y NIS2.

Dimensión Estratégica (12–24 meses):

- Participar en el Laboratorio de Privacidad de la AEPD para co-desarrollar herramientas LIINE4DU automatizadas.
- Adoptar el Indicador de Madurez en RGPD (ISMS Forum) como métrica de referencia para el Consejo de Administración.
- Explorar la certificación bajo ISO/IEC 27701 integrando los resultados del análisis LINDDUN como evidencia de Privacy by Design (Art. 25 RGPD).

References

13.
LINDDUN: The Threat Modeling Framework Built for Privacy (Not ... - The trees help teams identify specific, concrete threat scenarios rather than vague risk statements....
14.
LINDDUN privacy threat modeling framework | NIST - The LINDDUN threat modeling framework provides support to systematically elicit and mitigate privacy...
15.
Privacy Threat Modeling Frameworks | OLCreat
16.
A linddun-based Privacy Threat Modeling Framework for GenAI - arXiv - In this work, we focus on two fundamental research questions: (RQ1) What new privacy threats arise s...
17.
an architecture framework for privacy threat modeling - R Discovery - Article on Linddun maestro: an architecture framework for privacy threat modeling, published in Soft...
18.
[PDF] NOTA TÉCNICA - Si bien la metodología LINDDUN es un marco sólido y maduro para el modelado de amenazas para la priv...
19.
Robust and reusable LINDDUN privacy threat knowledge - This article introduces three contributions to address these shortcomings: (i) it defines the metamo...
20.
Robust and Reusable Linddun Privacy Threat Knowledge - Privacy threat modeling is intrinsically a complex analysis task that requires expertise in sophisti...
21.
linddun maestro: an architecture framework for privacy threat modeling - In this article, we present linddun maestro, an architecture framework which extends the traditional...
22.
La AEPD recibió en 2025 más de 2.700 notificaciones de brechas ... - La Agencia Española de Protección de Datos (AEPD) ha recibido 2.765 notificaciones de brechas de dat...

23.
122.000 incidentes de ciberseguridad en España en 2025 - INCIBE detecta 122.000 incidentes en 2025. El fraude y el malware crecen y elevan el riesgo para emp...
24.
LINDDUN: A Comprehensive Privacy Threat Analysis Framework - Linkability, I-Identifiability, N-Non Repudiation, D-Detectability, D-Information Disclosure, U-Cont...
25.
Structured threat knowledge representations
26.
EXAMPLES & CASES
27.
Privacy threat trees
28.
Methods | linddun.org - LINDDUN MAESTRO takes on a systematic and exhaustive approach in finding ... LINDDUN is created by D...
29.
[PDF] PILLAR: LINDDUN Privacy Threat Modeling using LLMs - The tool generates an automated assessment of identified threats and recommends privacy controls bas...
30.
[2410.08755] PILLAR: an AI-Powered Privacy Threat Modeling Tool - A new tool that integrates LLMs with the LINDDUN framework to streamline and enhance privacy threat ...
31.
privacy threat types - linddun.org - LINDDUN focuses only on non-compliance issues that directly derive from Linking, Identifying, Non-re...
32.
[linddun-go-categories](https://linddun.org/go/categories)
33.
A Comprehensive Privacy Threat Analysis and Risk Management ...

34.
PRASH: A Framework for Privacy Risk Analysis of Smart Homes - PMC - Smart homes promise to improve the quality of life of residents. However, they collect vast amounts...
35.
[PDF] Privacy Risk Assessment: From Art to Science, By Metrics - We then discuss how metrics for impact and likelihood can be combined to form privacy risk metrics...
36.
CVSS V4.0: steps for an advanced vulnerability assessment - INCIBE - Vector chains have been simplified for better understanding and clarity in scoring, improving accuracy...
37.
[PDF] ENISA THREAT LANDSCAPE 2025 - The ETL 2025 provides an overview of the European cyber threat ecosystem from July 2024 to June 2025...
38.
[PDF] LINDDUN PRO Privacy Threat Modeling Tutorial - Non-compliance as a linddun threat type focuses predominantly on the intersection between the privacy...
39.
Claves para 2026 en protección de datos y privacidad - Cepymenews - Claves para 2026 en protección de datos y privacidad · Protección datos pymes · Privacidad como eje ...
40.
El XVIII Foro de la Privacidad analiza el nuevo escenario de ... - El Foro analizará los principales retos regulatorios y operativos en materia de protección de datos,...
41.
Artificial intelligence act: Prohibited Systems - AESIA - These prohibited practices have been in force since 2 February 2025 and are as follows: 1. The use of ...
42.
Spain to impose massive fines for not labelling AI-generated content - Spain to impose massive fines for not labelling AI-generated content · Bill sets fines of up to \$38 ...
43.
Understanding practitioner perspectives on using privacy harm ... - Technically, when taking the risk-based approach for conducting a DPIA or a PIA, or conducting a privacy...

44.
LINDDUN User Group Meeting - The LINDDUN User Group Meeting connects, collaborates, and collects valuable feedback from industry ...
45.
[PDF] Threat Modelling with the GDPR towards a Security and Privacy ... - The resulting metrics framework demonstrates how the influence of privacy can minimise processing re...
46.
Protección de Datos recibió en 2025 más de 2.700 notificaciones de ... - La Agencia Española de Protección de Datos (AEPD) recibió en 2025 un total de 2.765 notificaciones d...
47.
Spain Issues Guidance Under the EU AI Act - Inside Privacy - The guidance offers a practical roadmap for compliance with the AI Act and reflects Spain's collabor...
48.
La Agencia Española de Protección de Datos publica su Plan de ... - El informe de 2025 recoge los objetivos y las actuaciones ejecutadas, estructuradas en torno a los s...
49.
La Agencia Española de Protección de Datos publica su Plan de ... - La Agencia Española de Protección de Datos (AEPD) ha hecho públicos el Plan de Actuación 2026 y el b...
50.
Instructions for MAESTRO | linddun.org - The LINDDUN team is currently developing dedicated tooling to facilitate the specification of the ri...
51.
Spain: Adopted AEPD technical note on LIINE4DU 1.0 methodology ... - The methodology covers threat categories such as data breaches, deception, unauthorised disclosures,...
52.
AEPD: Metodología para el modelo de amenazas - Privacy Driver - Si bien la metodología LINDDUN es un marco sólido y maduro para el modelado de amenazas para la priv...
53.
El análisis de amenazas de privacidad desde el punto de ... - Dialnet - La metodología LIINE4DU 1.0 introduce un catálogo de amenazas para la privacidad y una propuesta de ...

54.

Nuevas normativas, IA y marcos éticos: prepárate para el 2026 en ... - El 2026 se presenta como un año decisivo para el sector de la privacidad y la protección de datos. L...

55.

ENISA Cybersecurity Threat Landscape Report 2025 - The vast majority of cybercrime incidents targeting EU organisations involve ransomware (81.1%) and ...

56.

[PDF] LINDDUN privacy threat modeling - CIF Seminars @ KU Leuven - Threat 1. Using the forgot password feature we can identify a system user. DFD element(s). P2. Porta...

57.

CONTACT

58.

[PDF] Threat Modeling - The LINDDUN method is labor intensive and time consuming. It suffers from the same issues as STRIDE—...

59.

Instructions for PRO | linddun.org - Threat elicitation guidance is provided by the LINDDUN threat trees and mapping table. ... For the p...

LINDDUN: The Threat Modeling Framework Built for Privacy (Not ... - The trees help teams identify specific, concrete threat scenarios rather than vague risk statements....

LINDDUN privacy threat modeling framework | NIST - The LINDDUN threat modeling framework provides support to systematically elicit and mitigate privacy...

Privacy Threat Modeling Frameworks | OLCreat

A linddun-based Privacy Threat Modeling Framework for GenAI - arXiv - In this work, we focus on two fundamental research questions: (RQ1) What new privacy threats arise s...

an architecture framework for privacy threat modeling - R Discovery - Article on Linddun maestro: an architecture framework for privacy threat modeling, published in Soft...

[PDF] NOTA TÉCNICA - Si bien la metodología LINDDUN es un marco sólido y maduro para el modelado de amenazas para la priv...

Robust and reusable LINDDUN privacy threat knowledge - This article introduces three contributions to address these shortcomings: (i) it defines the metamo...

Robust and Reusable Linddun Privacy Threat Knowledge - Privacy threat modeling is intrinsically a complex analysis task that requires expertise in sophisti...

linddun maestro: an architecture framework for privacy threat modeling - In this article, we present linddun maestro, an architecture framework which extends the traditional...

La AEPD recibió en 2025 más de 2.700 notificaciones de brechas ... - La Agencia Española de Protección de Datos (AEPD) ha recibido 2.765 notificaciones de brechas de dat...

122.000 incidentes de ciberseguridad en España en 2025 - INCIBE detecta 122.000 incidentes en 2025. El fraude y el malware crecen y elevan el riesgo para emp...

LINDDUN: A Comprehensive Privacy Threat Analysis Framework - Linkability, I-Identifiability, N-Non Repudiation, D-Detectability, D-Information Disclosure, U-Cont...

Structured threat knowledge representations

EXAMPLES & CASES

Privacy threat trees

Methods | linddun.org - LINDDUN MAESTRO takes on a systematic and exhaustive approach in finding ... LINDDUN is created by D...

[PDF] PILLAR: LINDDUN Privacy Threat Modeling using LLMs - The tool generates an automated assessment of identified threats and recommends privacy controls bas...

[2410.08755] PILLAR: an AI-Powered Privacy Threat Modeling Tool - A new tool that integrates LLMs with the LINDDUN framework to streamline and enhance privacy threat ...

privacy threat types - linddun.org - LINDDUN focuses only on non-compliance issues that directly derive from Linking, Identifying, Non-re...

linddun-go-categories

A Comprehensive Privacy Threat Analysis and Risk Management ...

PRASH: A Framework for Privacy Risk Analysis of Smart Homes - PMC - Smart homes promise to improve the quality of life of residents. However, they collect vast amounts...

[PDF] Privacy Risk Assessment: From Art to Science, By Metrics - We then discuss how metrics for impact and likelihood can be combined to form privacy risk metrics...

CVSS V4.0: steps for an advanced vulnerability assessment - INCIBE - Vector chains have been simplified for better understanding and clarity in scoring, improving accura...

[PDF] ENISA THREAT LANDSCAPE 2025 - The ETL 2025 provides an overview of the European cyber threat ecosystem from July 2024 to June. 202...

[PDF] LINDDUN PRO Privacy Threat Modeling Tutorial - Non-compliance as a linddun threat type focuses predominantly on the intersection between the privac...

Claves para 2026 en protección de datos y privacidad - Cepymenews - Claves para 2026 en protección de datos y privacidad · Protección datos pymes · Privacidad como eje ...

El XVIII Foro de la Privacidad analiza el nuevo escenario de ... - El Foro analizará los principales retos regulatorios y operativos en materia de protección de datos,...

Artificial intelligence act: Prohibited Systems - AESIA - These prohibited practices have been in force since 2 February 2025 and are as follows: 1. The use o...

Spain to impose massive fines for not labelling AI-generated content - Spain to impose massive fines for not labelling AI-generated content · Bill sets fines of up to \$38 ...

Understanding practitioner perspectives on using privacy harm ... - Technically, when taking the risk-based approach for conducting a DPIA or a PIA, or conducting a pri...

LINDDUN User Group Meeting - The LINDDUN User Group Meeting connects, collaborates, and collects valuable feedback from industry ...

[PDF] Threat Modelling with the GDPR towards a Security and Privacy ... - The resulting metrics framework demonstrates how the influence of privacy can minimise processing re...

Protección de Datos recibió en 2025 más de 2.700 notificaciones de ... - La Agencia Española de Protección de Datos (AEPD) recibió en 2025 un total de 2.765 notificaciones d...

Spain Issues Guidance Under the EU AI Act - Inside Privacy - The guidance offers a practical roadmap for compliance with the AI Act and reflects Spain's collabor...

La Agencia Española de Protección de Datos publica su Plan de ... - El informe de 2025 recoge los objetivos y las actuaciones ejecutadas, estructuradas en torno a los s...

La Agencia Española de Protección de Datos publica su Plan de ... - La Agencia Española de Protección de Datos (AEPD) ha hecho públicos el Plan de Actuación 2026 y el b...

Instructions for MAESTRO | linddun.org - The LINDDUN team is currently developing dedicated tooling to facilitate the specification of the ri...

Spain: Adopted AEPD technical note on LIINE4DU 1.0 methodology ... - The methodology covers threat categories such as data breaches, deception, unauthorised disclosures,...

AEPD: Metodología para el modelo de amenazas - Privacy Driver - Si bien la metodología LINDDUN es un marco sólido y maduro para el modelado de amenazas para la priv...

El análisis de amenazas de privacidad desde el punto de ... - Dialnet - La metodología LIINE4DU 1.0 introduce un catálogo de amenazas para la privacidad y una propuesta de ...

Nuevas normativas, IA y marcos éticos: prepárate para el 2026 en ... - El 2026 se presenta como un año decisivo para el sector de la privacidad y la protección de datos. L...

ENISA Cybersecurity Threat Landscape Report 2025 - The vast majority of cybercrime incidents targeting EU organisations involve ransomware (81.1%) and ...

[PDF] LINDDUN privacy threat modeling - CIF Seminars @ KU Leuven - Threat 1. Using the forgot password feature we can identify a system user. DFD element(s). P2. Porta...

CONTACT

[PDF] Threat Modeling - The LINDDUN method is labor intensive and time consuming. It suffers from the same issues as STRIDE—...

Instructions for PRO | linddun.org - Threat elicitation guidance is provided by the LINDDUN threat trees and mapping table. ... For the p...